front matter

foreword

I first got to know Laurențiu Spilcă in 2022, when we virtually collaborated on a SpringOne presentation, and I was happy to finally meet him in person at Devoxx 2023 in Belgium. I was excited when he asked me to write this foreword. I'll start with an excerpt from the book:

"Applying a framework incorrectly leads to a less maintainable application. What is worse, sometimes those who fail in using the framework believe that it's the framework's fault."

This is such an important message! Over the years, I've gotten feedback from the community on several occasions that Spring Security is difficult to understand and has a steep learning curve. Whether or not that is the case, if you dive deep into the framework internals and really gain a profound understanding of the authentication architecture, you will learn how to take advantage of the framework's capabilities, and ultimately, it will become easier to use. This is where the book truly hammers it home and dives deep into Spring Security's authentication architecture, providing clear diagrams accompanied by detailed explanations of each of the main components that collaborate in the authentication-processing flow.

Throughout the book, Laurențiu makes clever use of analogies to help simplify the topic at hand. I really like the analogy used in the authentication architecture section, as he sums it up nicely:

"If you know this architecture, you're like a chef who knows their ingredients and can put together any recipe."

The collaboration diagram used to demonstrate how authentication processing works is excellent. It provides a high-level depiction of the flow and details the primary responsibility of each of the core components as it progresses throughout the book. The content has a natural flow, starting off with very simple examples and progressing to more advanced examples without overwhelming the reader.

After the book finishes examining the authentication architecture in detail, the next (logical) topic is authorization. This reminds me of a specific question that I repeatedly see in the community: "*What is the difference between authority, role, and permission?*" The book answers this question nicely as it provides very simple real-world examples of an authority, role, and permission, and how these can be associated with a user. It then progresses through general guidelines on how to model authorities in your application based on the functions available and the types of users of the system. Next, it uses these general principles and demonstrates how to define authorization rules in your Spring Security configuration to restrict access control.

Part 4 covers the topics of OAuth 2 and OpenID Connect 1.0. I think it's safe to state that the OAuth 2 and OpenID Connect 1.0 set of specifications is quite overwhelming, making it very difficult for anyone new to grasp their purpose and capabilities. However, this book provides an excellent high-level overview of the core concepts (roles, authorization grant types, access token formats, etc.) defined in the specifications and correlates how these are implemented in Spring Security and Spring Authorization Server. I love the analogy in the book on how the OAuth 2 specification is very similar to accessing an office building, where you need an access card (with limited access) to enter the meeting room in the building. It goes through this real-world use case and refers to the different parts of the OAuth 2 system and the roles that each of them plays.

It then builds a simple example using Spring Authorization Server along with Spring Security's Client and Resource Server support. The examples start off minimally and then demonstrate how to configure clients to perform various grant type flows, for example, authorization code (with PKCE), client credentials, and refresh token. Then it demonstrates common configuration scenarios, for example, configuring opaque tokens and using token introspection and token revocation. Next, it takes it a step further and shows more advanced scenarios with regard to configuring multi-tenancy for resource servers.

To sum it up, this book is a must-read for anyone looking to dive deep into Spring Security's authentication architecture and framework internals, as it will ultimately empower you to take full advantage of the framework's capabilities.

—**Joe Grandja, Spring Security Engineer, VMware by Broadcom**

preface

The journey through software development is an enthralling dance of building, learning, teaching, and often, unlearning. Ever since I began my journey in 2007, I've found myself gracefully expanding my role from being solely a developer to being a developer

and trainer. While both roles have their unique charm, it's the art of imparting knowledge, nurturing curiosity, and witnessing the aha moments of fellow learners that truly lights a fire in me. But let's face it, the realms of development and training are deeply intertwined. To be a torchbearer, illuminating the way for others, one must first have their feet firmly rooted in the constantly evolving terrains of software application.

Over the years, one realization stands out distinctly: while functional aspects of software might be its beating heart, nonfunctional attributes such as security, performance, and maintainability serve as its lifeline. It's simpler to pinpoint a glitch in a function than to navigate the murky waters of security vulnerabilities or performance lags. No wonder many developers, seasoned or not, often hesitate when faced with these nonfunctional intricacies.

Among these, security is not just paramount, but it's imperative. And in the vast realm of security frameworks, Spring Security emerges as a frontrunner, given the widespread adoption and trustworthiness of the Spring ecosystem in the enterprise application domain. Yet, a glaring challenge remains—the steep learning curve associated with Spring Security. The plethora of scattered resources online often feels like puzzle pieces that refuse to fit cohesively, leading even the most tenacious of learners astray.

It was these challenges, coupled with countless consultations witnessing improper or, even worse, vulnerable implementations of Spring Security, that sowed the seeds for the first edition of this book. My vision was clear: provide a guiding star to anyone, be it a Spring novice or aficionado, to master Spring Security.

With the second edition, we delve deep into Spring Security, reflecting on the innovations, changes, and experiences since the first edition. We enhance what was, learn from what wasn't, and introduce what's now essential. It remains my earnest hope that this second edition of *Spring Security in Action* will serve not just as a book, but also as a trusted companion in your journey toward creating secure, robust applications. I envisioned this book as a beacon that ensures that you not only save time but also build with confidence, knowing your applications stand resilient against the ever-evolving threats of the digital realm.

acknowledgments

Creating this book has been a journey I couldn't have embarked upon without the collective wisdom, support, and expertise of numerous exceptional individuals.

First and foremost, a heartfelt thank you to Daniela, my wife and guiding light. Her insights, constant encouragement, and unwavering faith have been instrumental throughout this project.

The entire team at Manning deserves a special mention. Their unwavering commitment and dedication have transformed this manuscript into the invaluable resource it is today. Among them, I'd like to particularly express my appreciation to Marina Micheals and Jean-François Morin. Their professionalism, support, and invaluable advice have significantly enriched this book.

A hearty shoutout to my friend, Ioana Göz, the creative genius behind the illustrations. Her knack for translating my abstract thoughts into delightful visuals has added a unique charm to the pages, providing readers with occasional smiles amid the technical content.

This book has greatly benefited from the meticulous eyes and feedback of numerous reviewers. Their keen observations and constructive feedback have been instrumental in refining its content. A special thanks goes to the dedicated reviewers from Manning, Amarjit Bhandal, Asif Iqbal, Cosimo Damiano Prete, Geoff Williams, Javid Asgarov, Justin Reiser, Luigi Rubino, Manoj Kumar, Marcus Geselle, Michele Adduci, Mikael Byström, Mikhail Malev, Najeeb Arif, Patrick Wanjau, Richard Meinsen, Sachin Handiekar, Simeon Leyzerzon, and Simone Sguazza, and to my trusted circle of friends who lent their expertise.

Lastly, to my colleagues and friends at Endava: your constant encouragement, thoughtful insights, and unwavering belief in my endeavors have been the silent forces driving me forward. I cherish and deeply value your support.

To everyone who has touched this project, in ways big and small, please know that your contributions have been the threads weaving the tapestry of this book. Thank you!

about this book

Security is paramount in software development, and integrating it from the onset is essential. *Spring Security in Action, Second Edition* dives deeply into using Spring Security to infuse application-level security into your projects. Mastery of Spring Security and its correct application is indispensable for every developer. Delving into an application's construction without this knowledge is a risk too great to take.

Who should read this book?

This book targets developers using the Spring Framework for enterprise applications. While I've tailored this book for those new to Spring Security, a foundational understanding of the Spring Framework is necessary, including

- Using the Spring context
- Crafting REST endpoints
- Working with data sources

Chapter 15 delves into security configurations for reactive applications. Hence, a prior understanding of reactive applications and their development using Spring is essential. As we navigate the book, I'll point you to supplementary resources to solidify or introduce necessary topics.

All examples in this book use Java. Given the widespread adoption of Java in the Spring ecosystem, it's assumed readers have a working knowledge of it. However, while some professionals might use languages like Kotlin, the foundation remains similar. The examples can be conveniently adapted to Kotlin if desired.

If you feel you need a refresher on the prerequisites before starting with this book, I warmly recommend *Spring Start Here* (Manning, 2021), another book I wrote.

How this book is organized: A roadmap

I crafted this book to guide you through the vast landscape of Spring Security, from fundamental concepts to more advanced areas. Each part of the book flows naturally into the next, making your journey of learning sequential and immersive. Here's a brief breakdown:

- Part 1: Say hello to spring security
  In this part, I introduce you to the modern landscape of security and Spring Security. We'll set the foundation by discussing the pivotal role of security in today's digital age and how Spring Security addresses these challenges.
- Part 2: Configuring authentication
  Dive deeply into the core of authentication. I cover essential topics such as user management, password protocols, the crucial role of filters in web application security, and the implementation of authentication.

- Part 3: Configuring authorization
  We move from authentication to authorization. Together, we'll explore endpoint-level authorizations, protective measures against threats such as CSRF, and managing CORS, and we'll delve into intricate method-level authorizations and filtering.
- Part 4: Implementing OAuth 2 and OpenID Connect
  In this part, I guide you through the world of OAuth 2 and OpenID Connect. You'll learn their significance and set up OAuth 2 servers, resource servers, and clients, thereby fortifying your application security.
- Part 5: Going reactive
  Here, I introduce you to the reactive programming paradigm, detailing how to secure reactive applications, so you can ensure your asynchronous operations remain tamper-proof.
- Part 6: Testing security configurations
  I emphasize the necessity of pre-deployment testing. We delve into the techniques to ensure your security configurations function precisely as intended.
- Appendixes
  Appendixes include resources for official documentation and further reading to supplement your learning and exploration.

While I envisioned this book as a step-by-step journey, those with some prior experience in Spring Security can navigate directly to their areas of interest. However, keep in mind that later chapters may reference concepts from earlier sections. If you're already familiar with Spring Security basics, consider starting with part 3 or part 4 for OAuth 2 and OpenID insights. Those keen on reactive programming can jump to part 5. No matter where you start, make sure to grasp each concept thoroughly to benefit from the subsequent chapters.

About the code

This book provides over 70 projects, which we'll work on starting with chapter 2 and up to chapter 18. When working on a specific example, I mention the name of the project that implements the example. My recommendation is that you try to write your own example from scratch together with the explanations in the book, and then only use the provided project to compare your solution with my solution. This approach will help you better understand the security configurations you're learning.

Each of the projects is built with Maven, making them easy to import to any IDE. I have used IntelliJ IDEA to write the projects, but you can choose to run them in Eclipse, STS, NetBeans, or any other tool of your choice. The appendix also serves as a refresher on how to create a Spring Boot project.

This book contains many examples of source code, both in numbered listings and in line with normal text. In both cases, source code is formatted in `a fixed-width font like this` to separate it from ordinary text. In many cases, the original source code has been reformatted; we've added line breaks and reworked indentation to accommodate the available page space in the book. In rare cases, even this was not enough, and listings include line-continuation markers (↪). Additionally, comments in the source code have often been removed from the listings when the code is described in the text. Code annotations accompany many of the listings, highlighting important concepts.

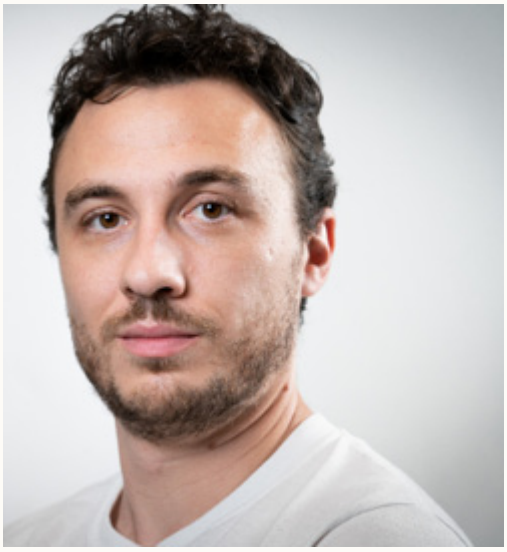
You can get executable snippets of code from the liveBook (online) version of this book at **https://livebook.manning.com/book/spring-security-in-action-second-edition**. The complete code for the examples in the book is available for download from the Manning website at **https://www.manning.com/books/spring-security-in-action-second-edition**.

liveBook discussion forum

Purchase of *Spring Security in Action, Second Edition* includes free access to liveBook, Manning's online reading platform. Using liveBook's exclusive discussion features, you can attach comments to the book globally or to specific sections or paragraphs. It's a snap to make notes for yourself, ask and answer technical questions, and receive help from the author and other users. To access the forum, go to **https://livebook.manning.com/book/spring-security-in-action-second-edition/discussion**. You can also learn more about Manning's forums and the rules of conduct at **https://livebook.manning.com/discussion**.

Manning's commitment to our readers is to provide a venue where a meaningful dialogue between individual readers and between readers and the author can take place. It is not a commitment to any specific amount of participation on the part of the author, whose contribution to the forum remains voluntary (and unpaid). We suggest you try asking the author some challenging questions lest their interest stray! The forum and the archives of previous discussions will be accessible from the publisher's website as long as the book is in print.

about the author



Laurențiu Spilcă has been a seasoned software developer and trainer since 2007, currently serving as a principal development consultant at Endava. In this role, he spearheads globally recognized projects with installations across the world. Laurențiu's twin passions have consistently been clear: delivering top-tier software and imparting knowledge to fellow developers.

Throughout his career, Laurențiu has ardently believed that it's not just about crafting high-quality software, but also about fostering a culture of shared knowledge and continuous learning. This conviction has led him to design and facilitate courses centered around Java technologies. Over the past decade, he has imparted knowledge to over 3,000 students and has been actively involved in courses at the Mathematics and Informatics Faculty of Bucharest University.

Beyond his contributions in the classroom, Laurențiu is also a recognized author. He has penned three pivotal books in the Java domain: *Spring Security in Action*, *Spring Start Here*, and *Troubleshooting Java*. These publications underscore his commitment to spreading knowledge and facilitating a deeper understanding of Java and its associated technologies.

His commitment to sharing insights extends to global platforms. From the streets of New York and San Francisco to the historic venues of Warsaw, Belgrade, and Berlin, Laurențiu has delivered presentations, tutorials, and workshops that resonate with international audiences.

In his quest to make knowledge widely accessible, Laurențiu also created a YouTube channel (youtube.com/@laurspilca), dedicated to Java and its adjacent technologies. On

this platform, beginners and seasoned developers can examine a wide range of topics, all curated and presented with Laurențiu's trademark clarity.

Outside of his professional endeavors, Laurențiu's passions diversify into the realms of travel, music, and the mesmerizing world of scuba diving. Whether navigating the depths of the ocean or the intricacies of code, Laurențiu's journey is a testament to his spirit of exploration and discovery.

Twitter/X handle: @laurspilca

About the technical editor

Jean-François Morin is a senior Java developer and architect at Laval University in Quebec City, Canada. He holds a B.Sc. in mathematics, a M.Sc. in computer science, and six Sun/Oracle Java certifications, including Java SE 17 Developer and JAVA EE 6 Enterprise Architect. He is also an experienced Java teacher and a regular Manning collaborator.

about the cover illustration

The figure on the cover of *Spring Security in Action, Second Edition* is captioned "*Homme de Murcie*," or "Murcie Man," taken from a collection by Jacques Grasset de Saint-Sauveur, published in 1797. Each illustration is finely drawn and colored by hand.

In those days, it was easy to identify where people lived and what their trade or station in life was just by their dress. Manning celebrates the inventiveness and initiative of the computer business with book covers based on the rich diversity of regional culture centuries ago, brought back to life by pictures from collections such as this one.

Previous chapter
‹ contents

Next chapter
Part 1. Say hello to Spring Security ›